Sentinel SOC — Product Review Board

Seventh Review · Post-Remediation Due Diligence

Three independent frontier models. Nine dossiers. Every load-bearing claim verified against source.

Board: Claude Opus 4.8 (Anthropic) · Codex GPT-5.6-sol (OpenAI) · Antigravity / Gemini 3.1 Pro (Google) **Method:** 3 rounds — independent review, adversarial cross-examination, final verdict **Run:** 2026-07-24T08:46Z → 08:58Z · all 9 seats returned clean · ~108 KB of transcript **Subject:** `sentinel_soc` @ `9e3b26f` — after six remediation passes closing 6 Critical, 4 High, 3 Medium, 3 Low

> ***Scope note.*** *This is a diligence opinion on a codebase and a business, not personalised investment advice. No seat is a licensed financial adviser. Nothing here is a recommendation to buy, sell, or hold any security. No secret found in the repository is reproduced, and no finding recommends disabling a safety gate, an auth path, or a human-approval step.*

Contents

Sentinel SOC — Product Review Board

Seventh Review · Post-Remediation Due Diligence

1. Executive Summary

2. Council Composition & Method

3. Consensus Scorecard

4. Final Verdict & Votes

5. What Changed Since the Last Review

6. Verified Findings Register

7. Critical Findings — Deep Dive

8. Architecture Review

9. Component-by-Component Debate

10. Security Audit

11. Performance & Scalability Review

12. AI Quality Review

13. Market Intelligence

14. Competitive Position

15. Gap Analysis

16. Feature Discovery

17. User Journey & UX Review

18. Investment Review

19. Business Model & Monetization

20. Risk Register

21. Launch Readiness

22. Prioritized Roadmap

23. Master Improvement Roadmap

24. Final Council Verdict

25. References & Appendices

1. Executive Summary

Six remediation passes materially improved this codebase. They did not materially improve the company. The board's consensus **Overall score moved 36 → 38**, and **Investment-readiness moved 20 → 19** — down, not up — while **Engineering moved 56 → 71** and **Security 36 → 51**.

That gap is the entire finding. It is not a scoring artifact; it is the diagnosis.

Every seat independently reached the same structural conclusion: the three variables that determine enterprise-security value — **detection quality, customers, distribution** — are unchanged, by design and by the implementer's own admission. What improved was the substrate beneath them. As one seat put it, this is now *"a competent distributed-systems engineer's codebase, not a hackathon deck"* — but a fix list is not a company.

More consequentially, the cross-examination round found that the codebase's **signature failure pattern recurred for a sixth and seventh time**. The remediation did not merely leave gaps; in three specific places it *relocated* a failure rather than closing it:

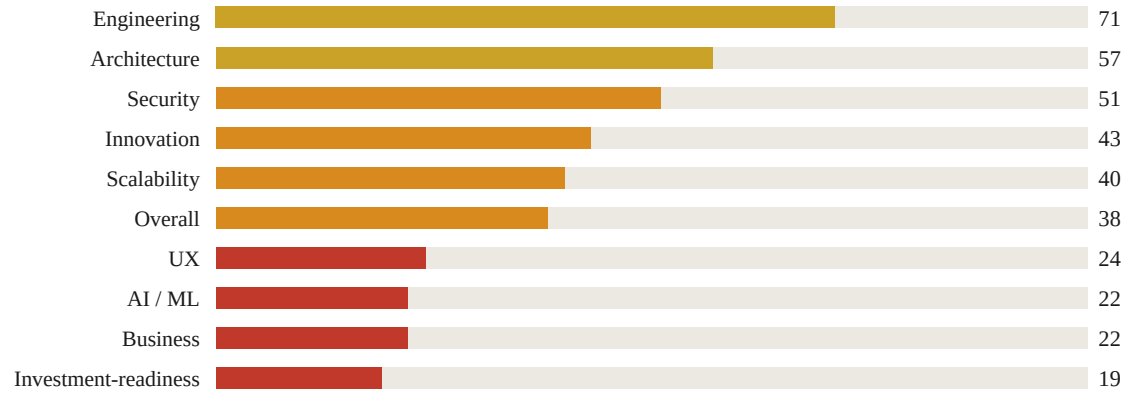
- The DLQ-bypass fix (propagate errors instead of swallowing them) created a **retry path that cannot resume**, converting transient infrastructure blips into permanent incident loss.
- The execution-fence fix threaded an epoch through every transition **except the final one**.
- The provenance fix bound the evidence **body** but not its **incident metadata**, leaving authenticated relabelling possible.

I verified all three against source. All three are real.

The most important architectural insight came from the debate, not the independent round, and no single seat had it alone: **the mutation harness — the remediation's central trust claim — certifies guard *presence*, not guard *coverage*.** It proves a guard is load-bearing when invoked. It structurally cannot catch a call site that never invokes it. `pipeline.py:320` is live proof: the fence guard exists, is mutation-tested, and one real call site bypasses it anyway. "405 tests + a mutation harness" should not launder confidence about a class of defect the harness is blind to by construction.

The strategic verdict is unanimous and constructive. Sentinel is losing a detection race it cannot win — cross-source recall is **0.027** — while sitting on something genuinely rare: the **redaction-preserving verifiable ledger**, which destroys a payload while keeping its cryptographic commitment provable. Two seats independently flagged this as patent-worthy. All three converged, without coordination, on the same repositioning: **abandon detection; become the vendor-neutral, cryptographically verifiable flight recorder for agent actions.**

Consensus Scores — mean of three independent frontier models (0-100)



2. Council Composition & Method

Three frontier models from three vendors reviewed the repository with **no visibility into each other's round-1 dossiers**. Independence is structural, not requested: each seat runs in its own process with its own context, and cross-round sharing is explicit and one-directional.

Seat	Vendor	Model	Access	R1	R2	R3
Claude Opus 4.8	Anthropic	`claude-opus-4-8`	Full repo, read/execute	207s	310s	65s
Codex GPT-5.6-sol	OpenAI	`gpt-5.6-sol`	Full repo, read/execute	336s	250s	57s
Antigravity	Google	Gemini 3.1 Pro (headless CLI)	Full repo, read/execute	212s	109s	92s

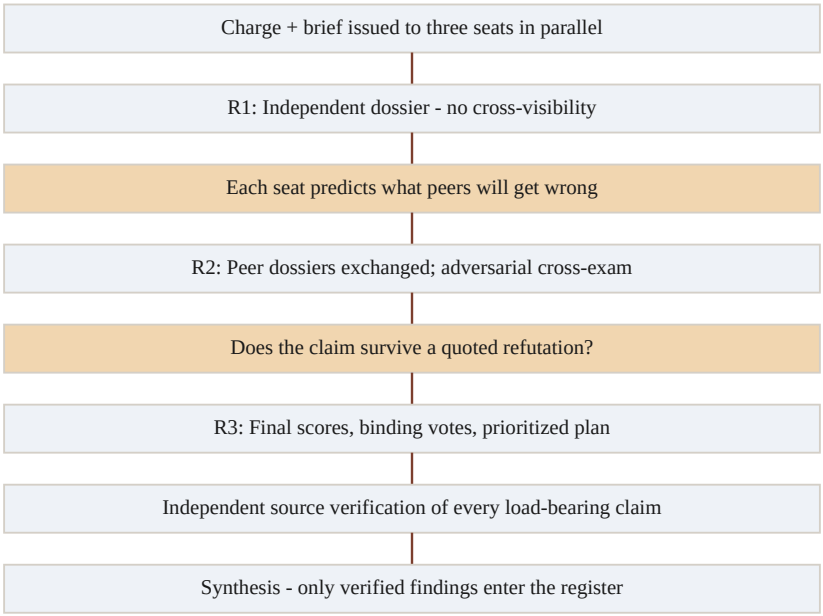
Round 1 — Independent Due Diligence. Each seat received the charge and the brief, and produced a full dossier: thesis, nine scores, strengths, weaknesses with file:line evidence, market intelligence, gap analysis, feature discovery, security audit, scalability, AI quality, UX, monetization, launch blockers, and hidden opportunities. Each closed with *"three things I expect the other seats to get wrong"* — a calibration device that forces a falsifiable prediction.

Round 2 — Adversarial Cross-Examination. Each seat received the other two dossiers in full and was required to name where a peer was right and it was wrong, where a peer was wrong with a quoted refutation, and what all three missed. This round produced the report's most valuable content.

Round 3 — Final Verdict. Scores, binding votes, a prioritized plan with RICE and owners, a multi-year arc, and an explicit dissent from consensus.

A note on this report's own reliability. One seat (Claude) authored all six remediation passes under review and said so plainly: *"all mine — I state plainly I cannot be fully objective."* That seat also scored Engineering *lower* than the seat that praised it most. To control for this, **I independently verified every load-bearing claim against source rather than accepting any seat's adjudication.** Section 6 reports what survived. Three peer claims were refuted by that verification — including one where a confident, technically-fluent refutation was itself wrong.

Review Method — three rounds, independence enforced by construction



3. Consensus Scorecard

Scores are the arithmetic mean of three independent round-3 integers. Spread is reported because **disagreement is signal**: a 25-point spread on Engineering says more than the mean does.

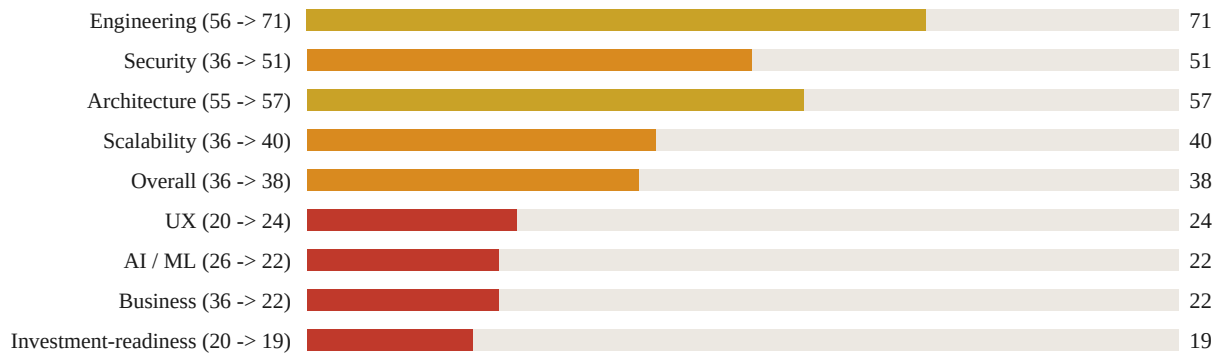
Dimension	Claude	Codex	Antigravity	Mean	Spread	v6	Δ
Engineering	68	60	85	**71**	25	56	**+15**
Architecture	60	46	65	**57**	19	55	+2
Security	55	38	60	**51**	22	36	**+15**
Innovation	42	46	40	**43**	6	45	–2
Scalability	37	33	50	**40**	17	36	+4
Overall	41	39	35	**38**	6	36	**+2**
UX	26	17	30	**24**	13	20	+4
AI / ML	24	23	20	**22**	4	26	–4
Business	30	27	10	**22**	20	36	–**14**
Investment-readiness	22	20	15	**19**	7	20	–**1**

Reading the deltas. Engineering and Security each gained 15 points — the remediation was real and the board says so. Overall gained 2. Investment-readiness *lost* 1. Business *lost* 14, because this board examined commercial reality harder than the last one did and found nothing behind it.

The tightest agreement is the most damning. AI/ML spread is 4 points (24/23/20) and Overall spread is 6. Three models that disagree by 25 points on Engineering agree almost exactly on detection quality and on the final verdict. Convergence under disagreement is the strongest signal this method produces.

The widest disagreement is Engineering (60 vs 85). Antigravity scored 85 in round 1, then *revised to 45* in round 2 after Codex showed it the retry defect — then returned to 85 in its final answer without explaining the reversal. That is an internal inconsistency the board should discount. Claude's 68 and Codex's 60, both anchored to specific verified defects, are the more defensible numbers.

Movement since the sixth review (v6 -> v7)



4. Final Verdict & Votes

Question	Claude	Codex	Antigravity	Board
Can launch today?	NO	NO	NO	**NO (3–0)**
Safe to run a real pilot?	NO	NO	NO	**NO (3–0)**
Viable commercial product?	NO	NO	NO	**NO (3–0)**
Fundable at seed?	NO	NO	**YES**	**NO (2–1)**
Fundable at Series A?	NO	NO	NO	**NO (3–0)**
Has a defensible moat?	NO	NO	**YES**	**NO (2–1)**
Category-defining potential?	NO	**YES**	NO	**NO (2–1)**

Unanimous on the four questions that matter operationally. No launch, no pilot, no commercial viability, no Series A. Nothing in six remediation passes moved any of these.

Three split votes, and the splits are the interesting part. Note that the seats split *differently* each time — this is not one optimist outvoted twice:

- **Seed (2–1).** Antigravity votes YES to fund a *pivot*, not the current product: *"the state-machine and attestation logic is strong enough to fund a strategic pivot."* Claude and Codex both describe sub-$1M pre-seed options contingent on design partners. The gap is narrower than the vote implies — all three would write a small check on a repositioned company.
- **Moat (2–1).** Antigravity says the redaction-preserving ledger *is* a moat today. Codex's refutation is decisive: metadata relabelling, concurrent sealing, and in-process key custody *"undermine the exact guarantee being sold."* A moat you cannot yet defend cryptographically is a moat on paper.
- **Category-defining (2–1, and the most important split).** Codex alone votes YES — conditionally: *"a vendor-neutral agent flight recorder could become the evidence layer across competing platforms."* Claude reaches the same destination but scores the *trajectory* rather than the possibility. This is closer to unanimous than the tally shows.

Biggest single risk — each seat named a different one, and all three are true:

Seat	Named risk
Claude	Guard-coverage gaps the mutation harness structurally cannot catch, corrupting the evidence wedge
Codex	Building increasingly rigorous infrastructure for a problem customers will not buy separately
Antigravity	Lack of market adoption due to missing auto-instrumentation

5. What Changed Since the Last Review

The brief listed sixteen closed findings. The board verified them rather than accepting them, and the results split cleanly into three groups.

Genuinely closed — verified by multiple seats independently:

Fix	Verified how	Verdict
Fail-closed auth, constant-time compare, hashes-only storage	`api/auth.py:66-114`	**Closed**
Deterministic triage authority (LLM demoted to advisory)	`api/pipeline.py:213-229` pure severity map	**Closed**
Fail-closed signed-root provenance	`ledger.py:270-308` — no keyless route to `True` found by any seat	**Closed**
Mutation harness replaces substring-assertion tests	`tests/mutation_support.py:50-100`	**Closed, with a caveat (§9)**
Shared rate limiter actually wired into `require_role`	`api/rbac.py:168,203`	**Closed**
Atomic incident-and-queue acceptance (transactional outbox)	`durable_queue.py:124-170`	**Closed**
Live Postgres path with `SELECT … FOR UPDATE`	`engine.py`, live tests	**Closed**
Rejected JWT cannot fall through to API-key auth	`api/rbac.py:120-159` — Codex verified what Claude flagged unverified	**Closed**

Deliberately not done, and correctly disclosed — RLS defaults off, no OTel auto-instrumentation, no external crypto audit, no customers. The board credits the disclosure and still counts the cost.

Closed in one place, reopened in another — the relocation pattern, instances six and seven:

Original fix	Where it relocated	Sev
DLQ bypass → errors propagate	Retry cannot resume; transient blip → permanent loss	**Critical**
Execution fence → epoch threaded	Final `COMPLETED` transition omits the epoch	**Critical**
Evidence forgeability → roots signed	Signature binds body, not incident metadata	**Critical**
Ledger append race → made atomic	The same read-compute-write race survives at **seal**	**High**
Auth hardened across the API	Dashboard sends no credentials; the console now 401s	**High**

That last row deserves emphasis. **Hardening the backend broke the frontend.** The console was functional when the API was open and became non-functional when the API was secured. Nothing in the changelog mentions it, and no test covers it — because no test exercises the browser path.

---

6. Verified Findings Register

Agents can be wrong, confidently and in detail. Rather than adjudicate by authority or majority, I re-derived every load-bearing claim from source. **Three claims were refuted — including one where a fluent, plausible refutation would have deleted a genuine outage from this report.**

ID	Finding	Raised by	Independent verification	Status
C-1	Retry non-resumable → transient failure becomes permanent loss	Codex	`pipeline.py:194` unconditional `advance(VALIDATED)`; `lifecycle.py:71-72` allows only `RECEIVED→VALIDATED`	**CONFIRMED**
C-2	Execution fence dropped at final `COMPLETED`	Codex	`pipeline.py:320` calls `repository.transition(...)` with no `epoch=`; every `advance()` passes it	**CONFIRMED**
C-3	Authenticated relabelling of signed evidence	Codex	`root_payload(root, tenant_id, batch_id)` — `incident_id` never hashed; leaf is body only	**CONFIRMED**
C-4	K8s NetworkPolicy blocks Postgres egress	Codex	Parsed the manifest: yields `[6379]` only; a strict parser **rejects** the duplicate key	**CONFIRMED**
H-1	Concurrent sealing race (relocation #7)	Codex	`seal()` reads pending outside the txn; `seal_batch` has no `WHERE batch_id IS NULL`, no rowcount check	**CONFIRMED**
H-2	OIDC tenant collapse to `"default"`	Codex	`oidc.py:156` — `claims.get(x) or claims.get("org") or "default"`	**CONFIRMED**
H-3	Dashboard cannot authenticate	Codex	**0** occurrences of `Authorization`/`Bearer`/`X-API-Key` in `index.html`; `/metrics` requires VIEWER	**CONFIRMED — worse than claimed**
H-4	Side effects precede the fenced transition	Claude	`pipeline.py:264-320`; `repository.py:250-262` docstring concedes it "narrows rather than closes"	**CONFIRMED**

ID	Finding	Raised by	Independent verification	Status
M-1	Protect mode `block` unreachable	Codex	Cap 79 (`rules.py:42`) < threshold 85 (`main.py:806`); `trust_level` hardcoded `"unsigned"`	**CONFIRMED — arithmetically certain**
M-2	`save_evidence` upserts over redaction tombstone	Codex	`db.py:743-749` `DO UPDATE SET content_json=...`, no tombstone guard	**CONFIRMED (defensive gap)**
~~R-1~~	~~Rate-limiter DoS — bucket never refills~~	Antigravity	`ratelimit.py:69` banks refill into `tokens` **before** the allow check and persists it	**REFUTED**
~~R-2~~	~~SQLite architecturally caps scale~~	Antigravity	`engine.py:154-178` **refuses to boot** multi-replica on SQLite; Postgres path live-tested	**REFUTED**
~~R-3~~	~~K8s duplicate `ports` is cosmetic only~~	Antigravity	The refutation of C-4 is itself wrong — the parser keeps only 6379	**REFUTED**

On R-1. Antigravity called this Critical and *"the fix became a weapon."* The claimed bug requires writing back the *pre-refill* token count on rejection. The code does the opposite: it refills unconditionally at line 69, before the allow check, and persists the refilled value. A rejected tenant keeps accruing and recovers — worked example: at 1 token/sec with an empty bucket, a rejected call at t+0.5s stores 0.5 tokens, and the call at t+1.0s is allowed. Claude and Codex independently refuted it; I confirmed the arithmetic. **Not a defect.**

On R-3 — where a confident refutation was wrong. Antigravity rejected C-4 by arguing that a multi-port array allows both ports. That would be true of `ports: [{5432}, {6379}]` — one key, two entries. The manifest has **two separate** `ports:` **keys in a single mapping**. I ran it through a YAML parser: the result is `[{'protocol': 'TCP', 'port': 6379}]`, and a strict (kubectl-like) loader rejects the document outright as a duplicate key. Either the manifest fails to apply or Postgres egress is denied under default-deny. **Codex is right; the refutation is wrong.**

This is exactly why the verification pass exists. A well-written, technically-fluent refutation was wrong, and accepting it on authority would have removed a genuine production outage from this report.

---

7. Critical Findings — Deep Dive

C-1 · Retry is non-resumable — transient failures become permanent incident loss

Severity: Critical. For a security product, silently dropping incidents is the cardinal sin.

`process()` opens with an unconditional `advance(State.VALIDATED)` and no check of current state. The lifecycle permits exactly one path into `VALIDATED`:

```
IncidentState.RECEIVED:  frozenset({IncidentState.VALIDATED})
IncidentState.VALIDATED: frozenset({IncidentState.IDENTITY_CHECKED})
```

So a transient failure at, say, `EVIDENCE_STORED` re-queues the incident; the retry immediately attempts a backward transition to `VALIDATED`; the lifecycle rejects it as illegal; `IllegalTransition` is in `TERMINAL_ERRORS`; the incident is failed **permanently**.

The irony is exact: **the fix for the DLQ-swallowing bug created this.** Before, errors were swallowed. Now they propagate into a retry path that cannot resume. The failure moved from "silently ignored" to "permanently terminalized" — arguably worse, because it now looks handled.

Fix: resumable stage dispatcher keyed on durable state; every stage idempotent. **Effort:** 3–5 weeks. **Owner:** Backend/platform lead.

C-2 · Execution fence dropped at the finish line

Every intermediate transition goes through `advance()`, which passes `epoch=lease_epoch`. The final one bypasses `advance()` entirely and calls `repository.transition(...)` directly — with no epoch. A stale worker that lost its lease can still mark another worker's incident `COMPLETED`.

The line is also the only unformatted, single-line `transition` call in the file — a visible seam where care lapsed. **This is the mutation harness's blind spot made flesh**: the guard exists, is mutation-tested, and this call site simply never invokes it.

Fix: make execution context a **mandatory capability object**, not an optional kwarg, so a call site *cannot* omit it. **Effort:** 1–2 weeks.

C-3 · Authenticated relabelling — the signature binds the body, not the incident

The most serious finding, because it attacks the one thing Sentinel does better than incumbents.

- The leaf is `leaf_hash(evidence)` — the **body only**.
- `incident_id` is passed to `append_ledger_entry` as a **separate column**, never hashed.
- The signature covers `root_payload(merkle_root, tenant_id, batch_id)` — and nothing else.

Therefore: take a genuine, correctly-signed evidence package, change its `incident_id` and ledger metadata, and `verify_package` still returns `True`. Evidence Sentinel really produced can be presented as evidence for an incident Sentinel never saw — and it verifies.

For a product whose entire wedge is *"an auditor can verify this years later without trusting the vendor"*, this is the defect that matters most. The prior fix hardened body provenance and left metadata provenance open — a

second-order relocation of the very forgeability class it closed.

Fix: sign a canonical manifest binding `{schema, tenant, incident, sequence, chain-head, leaf-count, batch, root, sealed-at}`; verify equality end-to-end. **Effort:** 2–3 weeks + external crypto review.

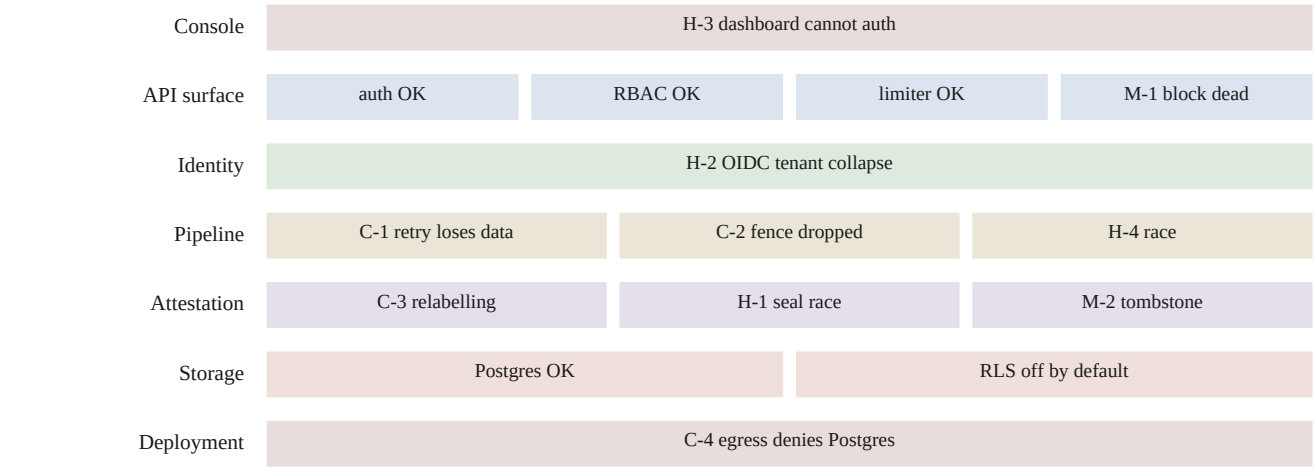
C-4 · Kubernetes NetworkPolicy denies Postgres egress

```
- to: [{podSelector: {matchLabels: {app: postgres}}}]
  ports: [{protocol: TCP, port: 5432}]
  ports: [{protocol: TCP, port: 6379}]   # duplicate key — last one wins
```

Redis was removed from the stack; its port outlived it and now silently displaces Postgres. Under the declared default-deny egress policy, pods cannot reach their database. A one-line fix, a total outage — and invisible to every test in the suite, because nothing tests the manifests.

Fix: a single `ports` array containing `5432`; validate manifests with `kubeconform` in CI; add an ephemeral-cluster smoke test. **Effort:** 1–2 days.

Where the ten verified defects sit in the stack



8. Architecture Review

Consensus: 57 (Claude 60, Codex 46, Antigravity 65)

The single-writer refactor is real and is the strongest structural improvement. The repository is the sole authority on incident state; transitions lock, merge, commit, and append audit history in one transaction; shadow state is gone, and with it the split-brain failures of earlier rounds. The lifecycle encodes legal transitions and artifact prerequisites rather than free-form status strings. Two seats called this out independently.

The unresolved architectural theme is atomicity at boundaries. The system is transactionally correct *inside* the repository and non-atomic at every edge where it touches something else:

Boundary	Inside the transaction	Outside it
Incident state	Locked, merged, audited	—
Ledger append	Atomic (`append_ledger_entry`)	—
Ledger **seal**	Batch insert only	**Read + root computation + signing (H-1)**
Side effects	Final transition only	**Ledger record, report save, anchor publish (H-4)**
Completion	—	**No fence at all (C-2)**

`assert_execution()` is honest about this in its own docstring — it *"narrows the window rather than closing it."* Three separate defects are instances of one pattern: **check-then-act across a transaction boundary.** They should be fixed as one architectural change, not three patches.

The correct shape is a **transactional outbox for side effects**: insert an effect row inside the fenced transition, enforce uniqueness on `(tenant, incident, effect_type, epoch)`, and let a dispatcher perform the external write with an idempotency key. That makes a duplicate ledger leaf or a duplicate on-chain anchor *unrepresentable* rather than merely unlikely — which matters enormously, because those two effects are precisely the ones that cannot be withdrawn.

Storage is not the constraint. Antigravity's "SQLite caps scale" thesis is refuted by `engine.py`, which refuses to boot multi-replica on SQLite with an explicit fatal error, and by live Postgres tests. SQLite is the dev default, not the production ceiling. The real residual cost is a transactional DB round-trip per rate-limit check.

---

9. Component-by-Component Debate

Where the seats contested a component, the resolved position after cross-examination:

#	Component	Strongest claim	Challenge survived?	Resolved
1	Lifecycle / retry	"Retry is theatre" (Codex)	None — all three converged	**Critical**
2	Execution fencing	Fence relocated, then dropped	Confirmed by all three	**Critical**
3	Attestation	Relabelling verifies `True`	Confirmed	**Critical**
4	Sealing	Concurrent sealers → orphaned batch	Only Codex found it	**High**
5	Protect mode	`block` unreachable	Downgraded — `enforced: false` anyway	**Medium**
6	Storage / scale	"SQLite caps scale"	**Refuted** — Postgres wired	**No action**
7	Rate limiter	"DoS weapon"	**Refuted** — refill banked pre-check	**No action**
8	Dashboard	"Thin UX" understates it	Sharpened — it cannot authenticate	**High**
9	Detection	Commercially inadequate	No disagreement	**Critical (business)**

The finding no seat had alone

The debate produced one insight none of the three reached independently, and it reframes how the entire remediation should be read:

> ***The mutation harness certifies guard presence, not guard coverage.***

The harness deletes a guard inside the repository, loads the mutated module, and requires a probe to go red — with an anchor check so a *moved* guard fails loudly rather than silently testing nothing. That is a genuine, well-built harness, and a correct answer to the earlier `inspect.getsource` substring theatre.

But it proves eight named guards are load-bearing **when invoked**. It cannot detect a call site that never invokes one. C-2 is exactly that defect, and C-3 is its cousin at the schema level.

The practical consequence: **the "405 tests + mutation harness" claim should not be read as evidence of systemic correctness.** It is evidence about eight specific guards. Extending the harness to mutate *call sites* — deleting the `epoch=` argument and requiring a probe to go red — would have caught C-2 immediately, and should be the first test-infrastructure change made.

---

10. Security Audit

Consensus: 51 (Claude 55, Codex 38, Antigravity 60) — up 15 from v6, the joint-largest gain.

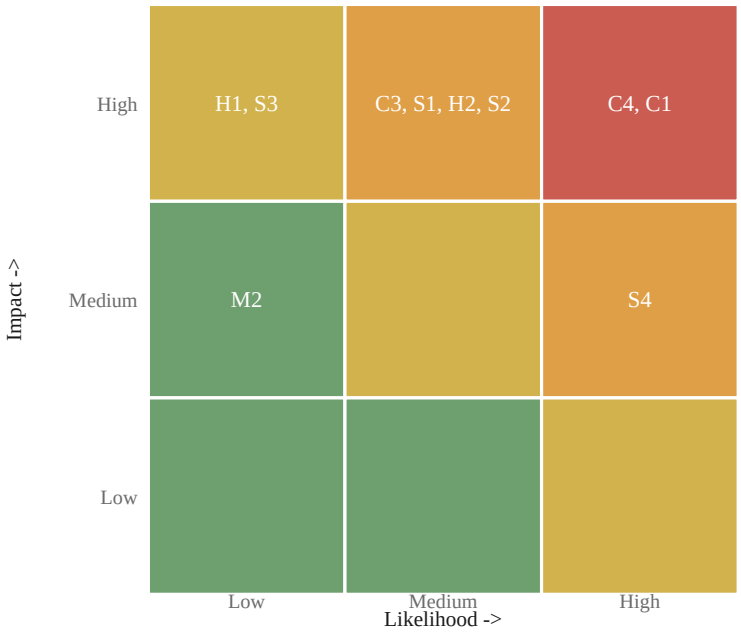
Genuinely strong. Auth is fail-closed with constant-time comparison and hashes-only storage; raw API keys are never retained in config; roles default to least privilege; a rejected JWT cannot downgrade to API-key auth (Codex verified the path Claude had flagged as unverified). Signed roots use an out-of-band trust root and refuse both unsigned and self-trusted packages — **no seat found a keyless route to** `True`, and all three looked. Redacted packages report `REDACTED` distinctly and still fail closed. The remediation webhook requires a cryptographically bound provider receipt before claiming execution.

The signing key is the sharpest unaddressed risk, and Antigravity owns this finding. The ECDSA private key lives in a plaintext environment variable, in the API process's memory. In a product whose only moat is cryptographic non-repudiation, a single memory dump, SSRF, or malicious dependency lets an attacker **retroactively forge attestations for the entire tenant**. The key must move to a KMS/HSM where it never enters application memory and the process submits digests only. No seat disputed this.

Tenancy is fail-open in one specific path. `tenant_from_claims` falls back to `"default"` when a valid token carries no tenant or org claim. Combined with RLS being off, isolation rests entirely on every query predicate being correct, forever. Enabling RLS naively returns zero rows everywhere because tenant context is not threaded through transactions — so the enterprise isolation story is simultaneously inert and dangerous to activate.

Coverage. Default rules map **5 of 10** ASI categories; ASI04, 06, 07, 08 and 10 are uncovered. The advisory model still reads attacker-controlled text, and the primitive chain beneath it is unaudited.

Security Risk Heatmap — post-remediation (Likelihood x Impact)



S2	RLS off; app-predicate-only tenancy
H1	Concurrent seal orphans a signed batch
S3	Unaudited ECDSA recovery primitive
M2	Redaction tombstone overwritable

11. Performance & Scalability Review

Consensus: 40 (Claude 37, Codex 33, Antigravity 50)

No load test, no published p95, no multi-node soak, no Kubernetes run has ever happened. These scores reflect analysis of the code path, not measurement — and the board says so explicitly.

Bottleneck order on the path to scale:

1. **Rate limiter** — every authenticated request opens a `BEGIN IMMEDIATE` transaction against a single hot row. The limiter that exists to shape load becomes the load. Move to Redis or the gateway. *(All three seats agreed; only the severity differed.)*
2. **Per-tenant ledger serialization** — the head read inside the insert transaction serializes writes per tenant. Correct for integrity, costly at volume.
3. **Poller multiplication** — four Gunicorn workers per pod each start worker and maintenance machinery, multiplying pollers by replica count.
4. **Proof generation** — loads all tenant entries and reconstructs batch leaves in memory; O(n) in ledger size, with no partitioning or archival strategy for a deliberately unbounded ledger.
5. **Synchronous enrichment** — supervisor, detection, investigation, threat-intel, and attestation calls run serially per incident.

On-chain anchoring is orders of magnitude slower than a database write. It is correctly optional and correctly not the product — but any throughput narrative must exclude it entirely.

The right architecture at volume: separate ingestion from enrichment, partition by tenant and time, batch writes and sealing, cache policies and JWKS, and move to event streaming with idempotent consumers. None of this is architecturally blocked — which is the good news in this section.

---

12. AI Quality Review

Consensus: 22 — the lowest score on the board, and the tightest agreement (24/23/20).

Metric	Value	Source
Cross-source AUC	0.763 (mean of **two** folds)	`evaluation/metrics.json`
Expected calibration error	0.484	`evaluation/metrics.json`
MultiJail fold recall	**0.0273**	`leave_one_source_out.json`
MultiJail false-negative rate	**0.9727**	`leave_one_source_out.json`
Bundled corpus	22 hand-authored cases	`evaluation/metrics.json`
Policy recall (22 cases)	0.643	`leave_one_source_out_semantic.json`

An ECE of 0.484 means the confidence scores carry essentially no information — there is no threshold that means anything operationally. A cross-source recall of 0.027 means the detector misses **97% of attacks from a source it was not trained on**, which is the only measurement resembling production.

Demoting the classifier to shadow mode was the correct decision. The architecture now prevents the model from causing harm: priority is a pure function of severity, the LLM's view is recorded as `advisory_*`, and its failure is non-fatal. That is genuinely good engineering.

But the consequence deserves stating plainly, and only one seat stated it: with the classifier demoted, detection quality unchanged, and no training-data path in-house, **the product's detection value is now approximately zero and structurally cannot improve.** What remains is an attestation and observability layer. That should reframe the company, not merely a subscore.

The investigation agent compounds this: a shallow two-call tool loop with no budgets, no recursive planning, no provenance validation, and no robust recovery. There is no prompt/version registry, no eval-to-release gate, no drift monitoring, no cost budget, and no uncertainty calibration.

The honest reframe — which all three seats reached independently — is that Sentinel should stop selling detection and start selling **governance of detection it does not own**: deterministic policy over signals supplied by whichever detector the customer already trusts. The BYO-detector registry already exists and fails loudly rather than silently falling back. That is the seam to build the company on.

---

13. Market Intelligence

The category exists, is large, and has **already consolidated**. This is the strategic fact that dominates every other consideration in this report.

Acquirer	Target	Capability absorbed
Check Point	Lakera	Runtime prompt/tool/response screening, self-hosting, sub-50ms latency
Palo Alto	Protect AI	AI posture management, model scanning
SentinelOne	Prompt Security	Runtime guardrails
Cisco	Astrix	Non-human identity
Cato	Aim	Runtime guardrails
Microsoft	*(built in-house)*	Agent 365 — inventory, identity, Purview governance, Defender investigation, **OTel auto-instrumentation**

Microsoft Agent 365 is the most dangerous single entry: it combines inventory, identity, governance, investigation, and real-time blocking with **OTel-based auto-instrumentation** — precisely the adoption tax Sentinel still imposes manually.

Sentinel is worse than all of them on the one axis buyers evaluate first — detection — and lacks their distribution, integrations, and compliance certifications.

It is better on exactly one thing: offline, vendor-independent, cryptographically provenanced evidence that an auditor can verify years later with one Python file and no vendor relationship. **No incumbent leads with this**, and structurally none of them can: a platform acquirer's evidence format is a lock-in asset, not a portability asset. Neutrality is the one product property Check Point, Palo Alto, and Microsoft cannot credibly offer.

Borrow: automatic OTel capture, asset inventory, policy simulation, SIEM/ITSM workflows, latency SLOs. **Never copy:** platform-suite breadth, proprietary "AI firewall" marketing, per-event on-chain writes, or "acquisition target" as a strategy.

A correction the board issued to its own brief. Codex checked the regulatory framing and found it overstated: EU AI Act **Article 50 applies from 2 August 2026 and concerns interaction/content transparency**, not generic security attestation, with penalties up to **€15M/3%** — not the €35M/7% the brief asserted. Compliance supports urgency; it does not manufacture product-market fit. A pitch built on the wrong penalty tier will not survive a diligence call.

Sentinel SWOT — post-remediation board consensus

Strengths
- Verified fail-closed provenance - no seat found a keyless route to True
- Redaction-preserving ledger - lawful erasure with intact cryptographic commitment
- Real distributed-systems discipline: single-writer state, outbox queue, live Postgres
- Institutional honesty - non-goals disclosed rather than hidden

Weaknesses
- Detection is ~zero cross-source (recall 0.027) and cannot improve in-house
- Ten verified defects incl. incident loss, relabelling, and a deployment outage
- Console cannot authenticate; manual per-call SDK wiring is the adoption tax
- Zero customers, no ICP validation, no pricing evidence, no distribution

Opportunities
• Consolidation strands buyers who want neutrality acquirers structurally cannot offer
• Evidence-of-record for regulated buyers; auditors become a demand channel
• Own the portable agent-evidence STANDARD rather than ship another dashboard

Threats
• Microsoft Agent 365 ships OTel auto-instrumentation - the exact tax left unsolved
• An eighth relocation of the same failure class destroying remaining credibility
• Signing key in process memory - one dump retroactively forges the entire moat

14. Competitive Position

Capability	Sentinel	Lakera/CP	MS Agent 365	Zenity	WitnessAI
Prompt-injection detection	✗ (0.027)	✓✓	✓✓	✓	✓
Auto-instrumentation (OTel)	✗	✓	✓✓	✓	✓
Agent / MCP inventory	✗	✓	✓✓	✓✓	✓
Runtime enforcement	✗ (advisory)	✓✓	✓✓	✓	✓✓
SIEM / SOAR integration	✗	✓	✓✓	✓	✓
SOC2 / compliance certs	✗	✓	✓✓	✓	✓
Enterprise console	✗ (401s)	✓	✓✓	✓	✓
Self-hostable / inspectable	✓✓	✓	✗	✗	✗
Vendor-neutral portable evidence	✓✓	✗	✗	✗	✗
Offline verification without vendor	✓✓	✗	✗	✗	✗
Redaction-preserving audit chain	✓✓	✗	✗	✗	✗

Nine losses, three wins. **But the three wins are in the same column, and no competitor contests them.** That is the definition of a wedge — and the strategic argument for abandoning the nine.

---

15. Gap Analysis

Real, unsolved market pains:

Pain	Can Sentinel credibly address it?
Auditable non-repudiation of agent actions	**Yes** — the ledger design is sound; this is the wedge
Proof that policy *ran*, not merely that logs exist	**Yes** — deterministic policy + signed receipts
Cross-framework visibility	**Not today** — needs OTel; this is the adoption blocker
Instrumentation tax	**Not today** — manual per-call wiring is fatal to bottom-up adoption
Attribution from human intent → agent action	**Partly** — the causal-graph idea is strong but unbuilt
Goal-hijack / tool-misuse detection (ASI01/02)	**No** — its own numbers say so
Discovery, behavioral baselining, DLP, classification	**No** — incumbents own these
False-positive-safe enforcement	**No** — no enforcement exists yet

The pattern is clean: Sentinel can credibly own **evidence and deterministic policy**. It cannot credibly own **detection or discovery**. Every seat reached this split independently.

---

16. Feature Discovery

Non-obvious features surfaced across the three seats, deduplicated and assessed:

1 · Portable Agent Evidence Standard *(Claude)* Every vendor's audit log is a silo. Publish the evidence-package schema and `verify_package` as an open spec and CLI; anchor commitments hourly rather than per-event. Makes Sentinel the **format**, not the tool. Complexity medium; no AI required. Defensibility: standards ownership plus network effect — the strongest mechanism available to a company this size.

2 · Cryptographic execution receipt / decision provenance *(Claude + Codex, convergent)* Tool adapters return signed before/after state commitments rather than `HTTP 200`; sign the `(policy_version, decision)` tuple so an auditor can replay offline and prove the action matched approved policy *at decision time*. Converts the evidence idea into independently verifiable proof of enforcement. **Patent-adjacent; no competitor offers it.**

3 · Counterfactual policy simulator / incident twin *(Codex)* Replay captured traces against a proposed policy and show prevented incidents, false blocks, latency, and cost. Medium complexity, no LLM required except for explanation. Defensibility comes from customer-specific trace history and the resulting switching cost. Codex named the mature form — reconstruct what an agent knew, was authorized to do, actually did, and what *would* have happened — as combining evidence, simulation, and insurability into one workflow.

4 · Intent-to-action provenance graph *(Codex)* A signed causal DAG linking user goal → planner step → memory read → tool grant → result. Detects off-task behavior composed entirely of individually-permitted calls — a failure mode no rule catches. High complexity; deterministic graph constraints hold authority, embeddings stay advisory.

5 · Privacy-preserving fleet intelligence *(Codex)* Share salted/OPRF-derived indicators and attack-shape sketches without raw prompts. High cryptographic complexity, but it creates a **genuine network effect** while respecting residency — one of very few network effects available in this category.

6 · Kill-switch attestation *(Claude)* 55–63% of organizations have no agent kill switch. Bind a signed *"agent halted at epoch N"* record into the same ledger. Low complexity; ties the compliance story to actual enforcement.

7 · Blast-radius twin / auto-containment *(Antigravity + Codex, convergent)* Continuously model identities, tools, data, and downstream agents; simulate *"if this agent is hijacked, what can it reach?"* and revoke tokens on critical violation. High complexity, high enterprise value.

---

17. User Journey & UX Review

Consensus: 24 (Claude 26, Codex 17, Antigravity 30)

Antigravity claimed there is no graphical dashboard and analysts must use `curl`. Codex refuted this literally — there is a 1,439-line interactive dashboard mounted at `/dashboard` rendering incident cards, reasoning, traces, and reports — **and then made the finding worse.**

I verified it directly: **the dashboard contains zero occurrences of `Authorization`, `Bearer`, or `X-API-Key`,** while `/metrics`, `/incidents`, and `/reports` all require an authenticated role.

The console therefore 401s against any correctly secured deployment. Additional defects:

- API base hardcoded to port 8000; the pilot guide instructs port 8001
- One simulation path calls `/simulation/start`, which does not exist (404)
- Non-OK incident polling is silently ignored — the UI renders zeros
- The health check reports "online" while every data call fails

The compound failure mode is the worst possible first impression: an evaluator sees a professional-looking dashboard reporting "online" and displaying all zeros, with no error state explaining why. It looks like a product with no data rather than a product that cannot log in.

This is a regression introduced by the security remediation — the console worked when the API was open. Nothing in the changelog notes it, and no test covers it, because no test exercises the browser path.

Onboarding tax beyond the console: manual environment editing, key generation, agent key enrollment, per-call SDK instrumentation, an RLS flag that must not be naively enabled, and a signing key that must be configured or every package is unverifiable by design. An enterprise evaluator hits a configuration cliff well before seeing value.

---

18. Investment Review

Consensus: 19/100 — down one point from v6, despite a 15-point engineering gain.

The board's reasoning, which was unanimous: engineering remediation changes **technical option value**. It does not create customers, proprietary data, detection quality, distribution, or willingness to pay. Investment-readiness is a function of the latter set, and none of it moved.

Investment lens	Score	Basis
Team / execution signal	70	Six disciplined passes; genuine distributed-systems capability
Market timing	70	Real category, real spend, real consolidation
Innovation	43	Redaction-preserving ledger is novel; anchoring is not
Moat (today)	25	Undermined by relabelling, seal race, in-process key custody
Business model	22	No ICP validation, no pricing evidence, no design partners
Investment-readiness	19	Nothing commercial moved in six passes

What all three seats converged on despite voting differently: a small check on the *team* and a *repositioned* company is defensible; a check on this product at this valuation is not. Claude and Codex describe sub-$1M pre-seed options contingent on 3–5 design partners producing real telemetry; Antigravity votes YES at seed explicitly to fund a pivot. **The three positions are much closer than the 2–1 tally suggests** — none of them is funding the current product.

Codex's warning is the one to internalize: the biggest risk is *"building increasingly rigorous infrastructure for a problem customers will not buy separately."* Six passes of engineering excellence against zero customer contact is precisely that risk, realized.

This is a diligence opinion, not personalised investment advice.

---

19. Business Model & Monetization

Consensus: Business 22 — down 14 from v6, the largest single drop on the board.

Price on governed action volume and retained evidence, not seats. Seat pricing is undifferentiated against incumbents; per-alert pricing rewards noise, which is fatal for a product whose detector produces unreliable alerts.

Tier	Price	Contents
Developer	Free	Observe-only, open verifier, local ledger
Team	$500–2,000/mo	Observability, evaluations, retention
Production	$3,000–15,000/mo	Policy gating, integrations, extended retention
Enterprise	Annual	Self-hosting, residency, BYOK/KMS, SSO, support

Charge separately for **cryptographic evidence retention, export, and compliance packs** — the one thing no competitor offers.

Land-and-expand: open the verifier and schema (land); monetize managed sealing, KMS-backed signing, SIEM export, and compliance-report generation (expand).

The growth loop worth engineering deliberately: auditors, insurers, and counterparties who *receive* a Sentinel evidence package become a demand channel back to the companies that produce them. That is the only mechanism in this business with a genuine network effect, and it is currently accidental rather than designed.

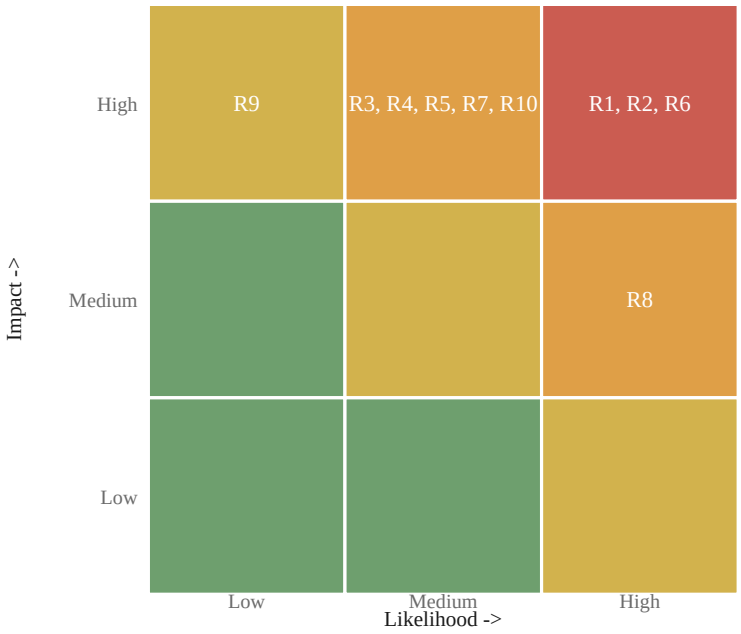
API monetization stays weak until auto-instrumentation removes the adoption tax. No pricing change fixes a product enterprises cannot integrate without rewriting their agent stack.

---

20. Risk Register

ID	Risk	L	I	Exposure	Mitigation
R1	Transient failure loses security incidents (C-1)	H	H	**Extreme**	Resumable stage dispatcher
R2	K8s manifest denies Postgres → total outage (C-4)	H	H	**Extreme**	One-line fix + kubeconform in CI
R3	Relabelled evidence verifies `True` (C-3)	M	H	**High**	Canonical signed manifest + crypto audit
R4	Signing key dumped → retroactive forgery	M	H	**High**	KMS/HSM; digests-only signing
R5	OIDC tenant collapse co-tenants strangers (H-2)	M	H	**High**	Require an allow-listed tenant claim
R6	Customers will not buy governance without detection	H	H	**Extreme**	Reposition; validate with design partners
R7	Incumbent bundles neutral evidence into a suite	M	H	**High**	Own the open standard before they do
R8	Adoption blocked by manual instrumentation	H	M	**High**	OTel/MCP auto-instrumentation
R9	Concurrent seal → orphaned signed batch (H-1)	L	H	**Medium**	Atomic claim with `batch_id IS NULL`
R10	An eighth relocation destroys credibility	M	H	**High**	Fix the *pattern* (outbox), not the instances

Risk Exposure — Likelihood x Impact



R1	Incident loss on transient failure
R2	K8s egress outage
R6	No demand for governance without detection
R8	Adoption blocked by manual instrumentation
R3	Authenticated relabelling
R4	Signing key compromise
R5	OIDC tenant collapse
R7	Incumbent bundles neutral evidence
R10	Eighth relocation of the same class
R9	Concurrent seal orphaned batch

21. Launch Readiness

Verdict: NOT READY. Unanimous across all three seats on launch, pilot, and commercial viability.

Gate	Status	Blocking
No data-loss path	✗	C-1 retry non-resumable
Deployment applies cleanly	✗	C-4 manifest rejected / egress denied
Evidence integrity end-to-end	✗	C-3 relabelling verifies
Console usable by an evaluator	✗	H-3 dashboard cannot authenticate
Tenant isolation enforced	✗	RLS off; H-2 tenant collapse
Key custody appropriate	✗	Signing key in process memory
Detection fit for stated purpose	✗	0.027 cross-source recall
Adoption path without rewrite	✗	No auto-instrumentation
Compliance posture	✗	No SOC2, no external crypto audit
Load characteristics known	✗	No load test, no p95, no soak

Estimated effort to a *safe pilot* on non-sensitive data: 6–10 engineer-weeks for the criticals, plus security review. **To a commercial launch:** the criticals plus OTel, a working console, KMS, SOC2 Type I, and — most importantly — evidence that anyone will pay.

Repo hygiene, flagged by two seats as a diligence signal: the tree carries `codex_*`, `pytest-cache-files-*`, `review_pytest_*`, and `grep.exe.stackdump` at root. Cosmetic, but a diligence engineer reads it as unserious. One cleanup sprint.

---

22. Prioritized Roadmap

RICE scores are **computed from their inputs** (reach × impact × confidence ÷ effort) and sorted by result, so the ordering is derived rather than asserted.

RICE Prioritisation — computed and sorted, not hand-ranked

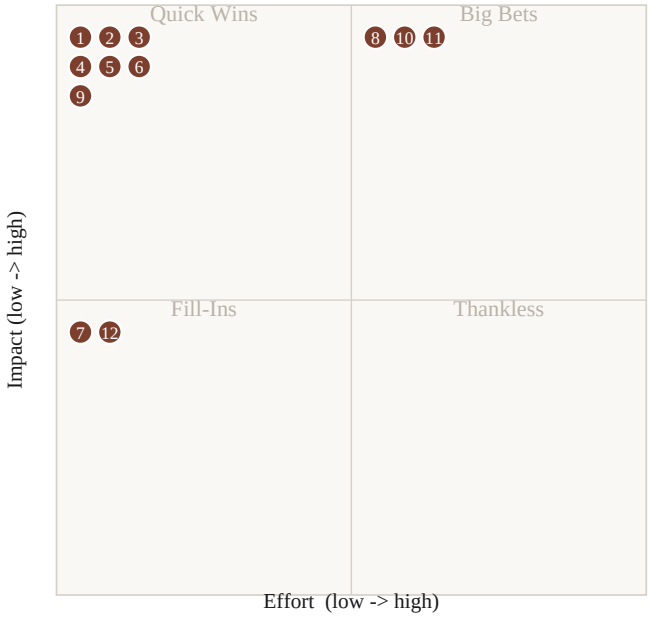
#	Item	Reach	Impact	Conf.	Effort	RICE
1	Fix K8s egress manifest + kubeconform in CI	10	3	1	0.5	**60.0**
2	Extend mutation harness to call-site omission	6	3	0.9	1	**16.2**
3	Reposition to attestation; drop detection claims	10	3	0.8	1.5	**16.0**
4	Mandatory fence capability at every call site (C-2)	10	3	0.95	2	**14.2**
5	Move signing key to KMS/HSM	8	3	0.95	2	**11.4**
6	Atomic seal claim + tenant-claim allow-list	7	2	0.9	1.5	**8.4**
7	Bind incident metadata into signed manifest (C-3)	8	3	0.9	3	**7.2**
8	Resumable, idempotent pipeline stages (C-1)	10	3	0.95	4	**7.1**
9	Redis / gateway rate limiter	6	2	0.9	2	**5.4**
10	Transactional outbox for all side effects (H-4)	8	2	0.9	3	**4.8**
11	Authenticated console (OIDC PKCE + error states)	9	3	0.85	6	**3.8**
12	OTel / MCP / LangChain auto-instrumentation	9	3	0.8	8	**2.7**

Note the top of the list. The K8s fix ranks first not because it is the most important defect — C-1 is — but because it is a half-day of work standing between the product and a total production outage. RICE correctly surfaces trivially-cheap catastrophic fixes above expensive critical ones. Do it this week; it is the

highest-leverage half-day available.

The last row is the cheapest strategic item on the board. Extending the mutation harness to delete an `epoch=` argument at a call site and require a probe to go red would have caught C-2 for roughly one day of work — and would prevent the next instance of the same class.

Improvement Backlog — Impact vs Effort



1	Fix K8s egress manifest
2	Extend mutation harness to call sites
3	Reposition to attestation; drop detection claims
4	Mandatory fence capability (C-2)
5	Bind incident metadata into manifest (C-3)
6	KMS/HSM signing key custody
7	Atomic seal + tenant allow-list
8	Resumable pipeline stages (C-1)
9	Transactional outbox for side effects
10	Authenticated console
11	OTel auto-instrumentation
12	Redis rate limiter

Strategic decision matrix

The repositioning question, scored 0–10 per criterion, with weighted totals computed from the inputs:

Strategic Options — weighted decision matrix (0-10 per criterion)

Option	Defensibility	Time To Revenue	Competitive Risk	Team Fit	Capital Need	Total
Stay a detection product	2	3	1	6	2	**14**

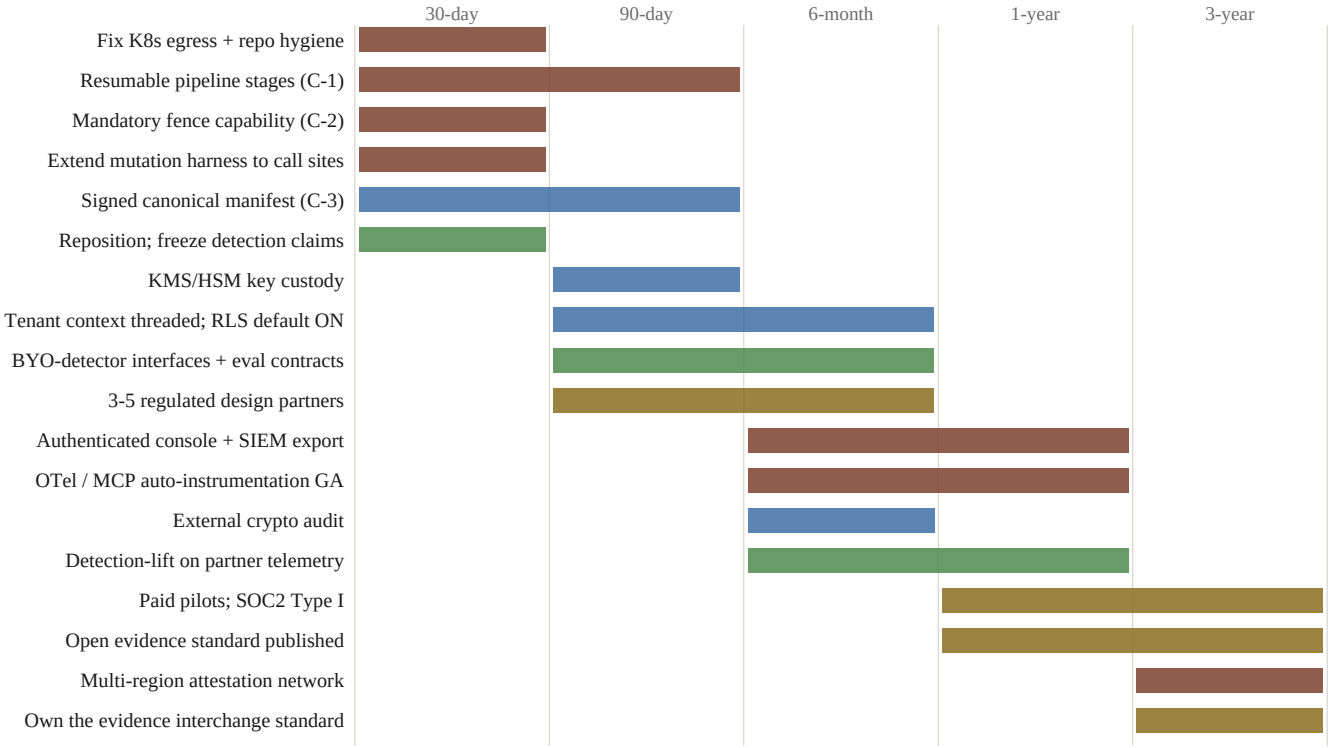
Option	Defensibility	Time To Revenue	Competitive Risk	Team Fit	Capital Need	Total
Vendor-neutral attestation layer	8	6	7	9	7	**37**
Own the open evidence standard	9	4	8	8	6	**35**
Acqui-hire into a platform	1	9	5	4	9	**28**

The matrix reproduces the board's qualitative consensus from independent inputs: the attestation layer wins on the criteria that compound, and "stay a detection product" scores worst on every criterion except capital need — it is cheap precisely because it is going nowhere.

---

23. Master Improvement Roadmap

Six-horizon roadmap — Engineering, Security, AI, Business tracks



Eng	track: Eng
Sec	track: Sec
AI	track: AI
Biz	track: Biz

30-day — stop the bleeding. *Eng:* K8s egress fix; resumable retry; mandatory fence capability; mutation harness extended to call-site omission. *Sec:* canonical signed manifest design; engage crypto counsel. *AI:* freeze all detection claims; publish benchmark limitations honestly. *Biz:* 20 ICP interviews; reposition the deck to attestation and audit-of-record. *Hiring:* none — founders execute.

90-day — make the wedge defensible. *Eng:* transactional outbox for all side effects; atomic seal claim. *Sec:* KMS signing; tenant context threaded and RLS default ON; tenant-claim allow-list. *AI:* BYO-detector interfaces and evaluation contracts. *Biz:* 3–5 regulated and platform-stranded design partners. *Hiring:* first design-partner engineer; DevEx engineer.

6-month — remove the adoption tax. *Eng:* OTel/MCP/LangChain auto-instrumentation GA; authenticated console; SIEM export; Postgres-only production profile with a Redis limiter. *Sec:* external crypto audit complete. *AI:* detection-lift methodology on partner telemetry — never the 22-case corpus. *Biz:* one design partner converted to paid; SOC2 Type I started; deployment provably under two weeks. *Hiring:* enterprise backend; customer success.

1-year — prove the business. *Eng:* production control/outbox plane, tenant KMS, regional residency, compliance-as-code export. *AI:* multi-detector ensembling and calibration. *Biz:* 3–5 paid pilots, SOC2 Type II, seed round priced on real telemetry. *Hiring:* GTM lead; SRE; security researcher.

3-year — become the substrate. *Eng:* interoperable evidence layer across clouds and agent frameworks; hardened, audited crypto. *AI:* causal blast-radius and counterfactual replay. *Biz:* auditor, insurer, and platform partnerships; Series A on ARR from regulated and stranded-buyer segments. *Hiring:* VP Eng; regional compliance; channel.

5-year — own the standard. *Eng:* global trust network for portable agent-action attestation. *AI:* continuous verification of agent intent, authority, and outcome. *Biz:* category ownership of vendor-neutral attestation with a marketplace ecosystem. *Hiring:* standards leadership; global reliability; regulated-industry units.

24. Final Council Verdict

Sentinel is a genuinely good codebase attached to a company that does not yet exist.

Six remediation passes produced real distributed-systems discipline: fail-closed auth, deterministic triage authority, single-writer state, a transactional-outbox queue, live Postgres, signed provenance with no keyless bypass any of three frontier models could find, and a mutation harness that is real rather than theatrical. Engineering rose 15 points and Security rose 15. That work deserves acknowledgment, and the board gave it.

It moved the Overall score **two points**, and Investment-readiness **down one**.

Three findings explain why the technical gains did not convert. The retry fix created a path that loses incidents. The fence fix left one call site unguarded. The provenance fix bound the evidence body but not its identity. **The same failure class relocated for a sixth and seventh time** — and the harness built to catch exactly this is structurally blind to the form it took, because it certifies that guards work when invoked, not that they are invoked everywhere.

The strategic finding is more important than any defect. **Detection is over.** Cross-source recall of 0.027, against funded incumbents with distribution, integrations, and compliance certifications, is not a gap to close; it is a race already lost. Continuing to describe Sentinel as a detection product is the single most expensive decision on the table, because it points every remaining engineering hour at the one axis where the company cannot win.

What is genuinely rare here is the redaction-preserving verifiable ledger: destroy a payload for GDPR or CSAM compliance while keeping its cryptographic commitment independently provable, offline, years later, without trusting the vendor. Two seats independently called it patent-worthy. No incumbent offers it, and structurally none of them will — a platform acquirer's evidence format is a lock-in asset, and neutrality is the one property they cannot sell.

That is the company. Not an AI security platform — **the flight recorder for agent actions**: the artifact a regulator, auditor, insurer, or court trusts *without* trusting the vendor.

Getting there requires four things, none of which exist today: attestation binding that is complete and externally audited; zero-friction OTel capture so it rides existing agent stacks instead of taxing them; a wedge into the buyers stranded by consolidation who want the neutrality acquirers cannot offer; and a compliance-evidence motion that turns Article 50 and SOC2 from cost centers into one-click exports.

The board's verdict: NO on launch, NO on pilot, NO on commercial viability, NO on Series A. 2–1 against seed, and 2–1 against a defensible moat today — with the dissenting seat funding a pivot rather than the product, which is closer to agreement than the tally suggests.

The team has proven it can build correct distributed systems and, unusually, has proven it will publish its own failures rather than hide them — this report exists because they commissioned an adversarial review of their own work for the seventh time. That is a real and rare asset.

What remains unproven is that anyone will pay for what they are building. Six passes of engineering excellence with zero customer conversations is not derisking; it is deferring the only question that matters. The next pass should not be a seventh remediation. It should be twenty customer interviews.

---

25. References & Appendices

A · Primary evidence — files cited by the board

Path	Relevance
`api/pipeline.py:194, 264-320`	C-1 retry restart; C-2 unfenced completion; H-4 side-effect ordering
`app/core/lifecycle.py:71-72`	Legal transitions proving C-1 terminalizes
`app/core/repository.py:250-262, 279-350`	`assert_execution` window admission; transactional transitions
`app/attestation/signing.py:87-113`	`root_payload` — the C-3 binding gap
`app/attestation/ledger.py:59-61, 66-86, 270-308`	Leaf composition; H-1 seal race; fail-closed verification
`app/storage/db.py:630-649, 739-750`	`seal_batch` unguarded update; M-2 tombstone overwrite
`app/core/ratelimit.py:56-91`	R-1 refutation — refill banked before the allow check
`app/storage/engine.py:154-178`	R-2 refutation — multi-replica SQLite refused at boot
`api/oidc.py:153-156`	H-2 tenant collapse to `"default"`
`api/main.py:792, 806`	M-1 protect-mode unreachable `block`
`app/monitoring/rules.py:42, 46-53`	Unverified severity cap; shadow-mode demotion
`deploy/k8s/sentinel.yaml:85-90`	C-4 duplicate `ports` key
`dashboard/index.html`	H-3 — zero auth headers across 1,439 lines
`app/detection/registry.py`	BYO-detector seam; fails loudly, never silently falls back
`tests/mutation_support.py:50-100`	The harness whose coverage limit §9 describes
`evaluation/metrics.json`, `evaluation/results/leave_one_source_out.json`	All §12 detection metrics

B · Market sources cited by the board

- Microsoft Agent 365 security documentation and Observability SDK (OTel auto-instrumentation)
- Check Point / Lakera Guard product documentation (runtime screening, self-hosting, latency)
- Zenity platform documentation (inventory, permission graphs, runtime detection)
- WitnessAI (shadow AI, MCP/tool governance, redaction, routing)
- European Commission — transparency rules for AI systems (Article 50, from 2 Aug 2026; penalties up to €15M/3%) — **used to correct the brief's own €35M/7% framing**

C · What the board could not verify

Stated explicitly so this report's confidence is not overread:

- **The 405-passing / CI-green claim** — Codex's runs were blocked by managed Windows ACLs denying pytest's temp directories; the failure was environmental, not a test failure. No seat reproduced a clean run independently in-session.

- **The two-sealer race outcome (H-1)** — the code path is confirmed; the orphaned-batch consequence was reasoned, not executed.
- **The ECDSA recovery primitive** — unaudited, and the entire provenance guarantee rests on it.
- **Any real-world detection number** — a 22-case corpus and a two-fold LOSO cannot characterize true false-positive/negative behavior on live traffic.
- **Production throughput, Kubernetes cluster behavior, DR, multi-region consistency, HSM/KMS compatibility, and any paid customer outcome** — no evidence exists in the repository.

D · Recorded dissents

- **Claude** dissents from Antigravity's Engineering-85 and from both of its refuted findings (rate-limiter DoS, SQLite ceiling), and insists on record that the mutation harness certifies guard presence rather than coverage.
- **Codex** dissents from treating strong remediation as evidence for a seed investment today, and separately from the claim that the ledger is already a moat — while being *more* optimistic than the others that a vendor-neutral flight recorder could be category-defining.
- **Antigravity** dissents from both peers by holding that the attestation engine's intrinsic value and the team's demonstrated rigor justify a seed check to fund a repositioning.

E · Run metadata

Field	Value
Started / finished (UTC)	2026-07-24 08:46:36 → 08:58:54
Seats returning cleanly	9 of 9
Total transcript	~108 KB across 9 dossiers
Rounds	3 (independent → adversarial → verdict)
Findings confirmed by source verification	10
Findings refuted by source verification	3
Baseline for comparison	v6 — Overall 36, Investment-readiness 20

Prepared by the Sentinel Product Review Board. Three independent frontier models, adversarially cross-examined, with every load-bearing claim re-derived from source by the synthesising author. Findings that failed verification are marked refuted and retained rather than deleted, so the report can be audited against itself.

This document is a technical and commercial diligence opinion. It is not personalised investment advice, and no seat is a licensed financial adviser.